

Site: **Your Learning Platform**

Module: **Information Security Management April 2026 (ISM_PCOM7E April 2026)**

Glossary: **Module Wiki**

GDPR, PCI-DSS and HIPAA Applicability and Compliance Evaluation

The organisation described in the assessment processes customer personal data and conducts online transactions, meaning GDPR and PCI-DSS are the most relevant compliance frameworks. GDPR applies to organisations processing personal data of individuals within the UK/EU and requires lawful, fair and transparent processing, alongside strong technical and organisational security measures (ICO, 2020). PCI-DSS applies where payment card data is stored, processed or transmitted, requiring strict controls to protect cardholder information and reduce fraud risk (PCI Security Standards Council, 2020). HIPAA does not apply in this context as it is limited to organisations handling protected health information within healthcare systems (HIPAA Guide, 2020).

In evaluating the organisation, key GDPR risks include weak encryption, insufficient access control, and limited audit logging, which increase the likelihood of data breaches and non-compliance with accountability and confidentiality principles (ENISA, 2022). For PCI-DSS, risks include inadequate authentication mechanisms, poor network segmentation, and weak endpoint protection, which increase exposure to payment data compromise (Verizon, 2024).

Compliance can be assessed through Data Protection Impact Assessments (ICO, 2020), penetration testing, vulnerability scanning, and configuration audits. In addition, ISO/IEC 27001-aligned internal audits can be used to evaluate governance, risk management, and control effectiveness (ISO, 2022). Continuous monitoring and incident response testing further help verify operational compliance (NIST, 2020).

To meet these standards, the organisation should implement multi-factor authentication, encryption for data at rest and in transit, and role-based access control. It should also introduce continuous logging and monitoring, regular patch management, security awareness training, and formal incident response procedures. These controls align with best practice frameworks and significantly reduce cyber risk exposure.

References:

ENISA (2022) *Threat Landscape for Data Breaches*. European Union Agency for Cybersecurity. Available at: <https://www.enisa.europa.eu> (Accessed: 24 May 2026).

HIPAA Guide (2020) *HIPAA for Dummies*. Available at: <https://www.hipaaguide.net> (Accessed: 24 May 2026).

ICO (2020) *Guide to the General Data Protection Regulation (GDPR)*. Information Commissioner's Office. Available at: <https://ico.org.uk> (Accessed: 24 May 2026).

ISO (2022) *ISO/IEC 27001 Information Security Management Systems*. International Organization for Standardization. Available at: <https://www.iso.org> (Accessed: 24 May 2026).

NIST (2020) *Computer Security Incident Handling Guide (SP 800-61 Rev. 2)*. National Institute of Standards and Technology. Available at: <https://www.nist.gov> (Accessed: 24 May 2026).

PCI Security Standards Council (2020) *PCI Security Standards Overview*. Available at: <https://www.pcisecuritystandards.org> (Accessed: 24 May 2026).

Verizon (2024) *Data Breach Investigations Report (DBIR)*. Available at: <https://www.verizon.com/business/resources/reports/dbir/> (Accessed: 24 May 2026).

